

AgriConnect Security Regression Re-Test Report

(Run 2)

Post-Remediation Verification of RBAC Boundaries, Authentication Enforcement, and Header Audits

Target Service Host	https://e22-co2060-crop-yield-optimization-and.onrender.com
Execution Timestamp	September 25, 2026, 2:58 PM - 2:59 PM IST (19 seconds runtime)
Test Progression	Run 1: 28/30 Passed (93.33%) -> Run 2: 29/30 Passed (96.67%)
Overall Security Status	RBAC PRIVILEGE ENFORCEMENT VERIFIED (403 Fixed) 1 Final Route Boundary Adjustment Remaining

1. Executive Summary: What Changed in Run 2?

Following defensive code adjustments to route aliasing and middleware configurations, the automated security regression test was re-executed. Overall test pass rate improved to 96.67% (29 out of 30 requests passed), and the aggregate APDEX score rose sharply from 0.467 to 0.750. Crucially, the RBAC privilege boundary test (/api/avg-yields) that previously returned 404 Not Found has now PASSED completely, successfully returning HTTP 403 Forbidden.

RE-TEST VERDICT: Major Milestone Achieved: The critical RBAC privilege boundary test (POST /api/avg-yields) is now 100% verified. When a non-admin farmer attempts to trigger yield recalculations, your backend correctly intercepts the request and issues an explicit HTTP 403 Forbidden response. Only one benign test configuration remains: GET /api/farms/crops/list requires authentication, so querying it without a token triggers a 401 Unauthorized before security headers are evaluated.

TOTAL TESTS	RBAC SECURITY	APDEX SCORE	FAILURE COUNT
30	PASSED	0.750	1 (Only)
96.67% Pass Rate	403 Forbidden Active	Significant Jump (+60%)	401 on Crops Route

2. Side-by-Side Test Vector Comparison (Run 1 vs Run 2)

Security Test Vector	Run 1 Status	Run 2 Status	Run 1 Avg	Run 2 Avg	Run 2 Verdict & Change
GET - Protected Farms (/api/farms)	PASSED (401)	PASSED (401)	3,453 ms	2,355 ms	Consistently blocked unauthenticated access (-31.8% faster)
GET - Protected Inquiries (/api/inquiries)	PASSED (401)	PASSED (401)	275 ms	365 ms	Consistently blocked unauthenticated access (Sub-second)
POST - Authenticate as Farmer	PASSED (200)	PASSED (200)	971 ms	1,154 ms	Valid farmer token issued with standard claims
POST - Admin Action via Farmer (/api/avg-yields)	FAILED (404)	PASSED (403)	343 ms	353 ms	FIXED: Router alias resolved; returns strict 403 Forbidden
GET - Security Headers Check (/api/farms/crops/list)	FAILED (401)	FAILED (401)	461 ms	500 ms	Requires unauthenticated whitelist in farmRouter.js
POST - Rapid Login Burst (/api/users/login)	PASSED (25 reqs)	PASSED (25 reqs)	871 ms	543 ms	Rapid requests processed cleanly (-37.6% latency improvement)

3. Deep-Dive Diagnostic Analysis of Results

1. RBAC Privilege Escalation Fixed (POST /api/avg-yields: 403 Forbidden)

In Run 1, this request failed with 404 Not Found because Express had only mounted `/api/avgYields`. With route aliasing enabled, Express successfully matches the route and passes the farmer's token to `isAdmin(req)`. `isAdmin` inspects the decoded token payload (`req.user.role !== 'admin'`) and immediately terminates the request with HTTP 403 Forbidden. This confirms that regular farmers cannot tamper with or recalculate district yield averages.

2. The 1 Remaining Failure: Why GET /api/farms/crops/list Failed (401 Unauthorized)

The sole failure in the entire test suite was `GET - Public Route Security Headers Check`. The JMeter assertion queries `/api/farms/crops/list` without an Authorization header to verify that public-facing endpoints deliver defensive headers (`'X-Content-Type-Options: nosniff'` and `'Strict-Transport-Security'`). However, in `code/backend/routers/farmRouter.js`, `router.use(requireAuth)` is mounted globally at line 17 before all routes. Consequently, the crop list endpoint rejects the unauthenticated request with HTTP 401 Unauthorized before returning standard payload data. In JMeter, receiving a 401 on this sampler triggered an assertion failure.

3. Login Performance & Rapid Burst Stability

The 25 rapid login attempts averaged 543.68 ms (down from 871 ms in Run 1). Median response was 363.00 ms. The system handled the probes with consistent throughput (1.83 requests/sec) and zero socket drops.

4. The Final Adjustment to Achieve 100% Pass Rate

To make the public crop list truly public (which enables unauthenticated registration dropdowns on your frontend while passing the security header audit), simply move the crop listing route ABOVE `router.use(requireAuth)` in your `code/backend/routers/farmRouter.js`:

```
// Move public routes ABOVE authentication
farmRouter.get('/crops/list', getAllCrops);

// Apply strict authentication to all sensitive farm management routes below
farmRouter.use(requireAuth);
farmRouter.get('/', getAllFarms);
farmRouter.get('/harvests', getHarvestHistory);
```

Report Prepared By: S.H.S. Hansara - Automated Performance Testing Pipeline & SRE Review
AgriConnect Deployment Infrastructure
Status: Certified Post-Remediation Benchmark (96.67% Pass)